

Equifax Data Breach: When Security Failures Cost Billions

Suresh Paul*

January 19, 2026

Abstract

In 2017, Equifax suffered one of the largest data breaches in history when hackers stole personal information from 147.9 million Americans—nearly half the U.S. population. The breach exposed names, Social Security numbers, birth dates, addresses, and driver's license numbers through a chain of preventable security failures. A critical software patch sat unapplied for two months. An expired SSL certificate disabled monitoring for 19 months. Data sat unencrypted. Networks remained unsegmented. The result? Attackers roamed inside Equifax's systems undetected for 76 days, copying records that would enable identity theft for decades. The company ultimately paid over \$1.4 billion in settlements and fines, while executives resigned with millions intact and victims received an average of \$2.88 each. This case examines how cascading technical failures, inadequate corporate governance, and misaligned incentives created disaster—and raises fundamental questions about accountability when companies hold data consumers never chose to provide.

1 The Company Nobody Chose

Equifax is one of the big three credit bureaus in America, along with Experian and TransUnion. With \$3.4 billion in revenue and operations in 24 countries as of 2016, Equifax maintained credit files on over 800 million consumers worldwide and 88 million businesses. The company collected an enormous amount of personal information: Social Security numbers, birth dates, addresses, phone numbers, credit card accounts, loan histories, mortgage details, payment records, credit scores, and employment histories.

Here's what makes credit bureaus unusual. You didn't choose Equifax. You can't opt out. When you apply for a credit card or a mortgage, the bank reports your information to the bureaus automatically. The bureaus then sell access to this data back to lenders, employers, and others making decisions about you. Consumers are the product, not the customer.

*Paul: Algorithm Basics and Baldwin Wallace University (spaul@bw.edu).

This market structure matters. With only three major players and high barriers to entry, the credit bureau industry operates as an oligopoly. Network effects make it nearly impossible for competitors to emerge—everyone reports to the same three bureaus because everyone else does. So if you're an American with any credit history, Equifax has your data whether you like it or not.

That arrangement creates a particular kind of responsibility. When consumers can't choose their data collector and can't opt out, security becomes not just good business practice but a fundamental obligation. Equifax failed that obligation catastrophically.

2 How the Breach Happened

On March 7, 2017, the Apache Software Foundation announced a critical vulnerability in Apache Struts, a popular web application framework. The flaw, designated CVE-2017-5638, allowed remote code execution—meaning attackers could run whatever commands they wanted on vulnerable servers. A patch was immediately available.

Equifax ran vulnerability scanners that should have detected the problem. The scanners missed it. The patch wasn't applied.

Sometime in mid-May 2017, hackers found Equifax's unpatched server and exploited CVE-2017-5638 to gain initial access. Once inside, they discovered a network architecture that made their job remarkably easy. Equifax's internal network was essentially flat—no meaningful segmentation to contain breaches. If you got into one system, you could reach others. The attackers moved laterally through the network until they located database servers holding consumer credit data.

Those databases stored 147.9 million records in plain text. No encryption at rest. The attackers began copying everything.

Meanwhile, Equifax's security monitoring failed to notice. Part of the problem was technical: an SSL certificate used for inspecting network traffic had expired 19 months earlier. Without the ability to decrypt and examine traffic, monitoring tools couldn't detect the massive data exfiltration happening right in front of them.

For 76 days, the attackers had free rein inside Equifax's systems. They copied names, Social Security numbers, birth dates, addresses, and for some victims, driver's license numbers and credit card details. On July 29, 2017—more than two months after the breach began—Equifax finally discovered the intrusion.

What happened next made things worse. On August 1st and 2nd, three Equifax executives sold \$1.8 million in company stock. The breach had been discovered internally, but the public didn't know yet. The sales triggered an SEC investigation into possible insider trading.

Equifax announced the breach publicly on September 7, 2017. By then, the stolen data included information on 147.9 million people—the most comprehensive data breach in American history up to that point.

3 The Chain of Failures

The Equifax breach wasn't one mistake. It was a cascade of failures at every defensive layer:

Failure #1: Unpatched Software. The initial entry point shouldn't have existed. Apache Struts CVE-2017-5638 had a patch available the same day it was announced. Equifax's vulnerability scanners were supposed to catch exactly this kind of risk. They didn't. Whether the scanners were misconfigured, the patching process was broken, or staff simply didn't act on the findings, the result was the same—a two-month window for attackers to find and exploit a well-known, easily fixed vulnerability.

Failure #2: Expired SSL Certificate. Security monitoring depends on seeing what's happening on your network. Encrypted traffic needs to be decrypted and inspected. Equifax's SSL certificate for this purpose had expired 19 months before the breach. That's not a minor oversight or a near-miss—that's 19 months of effectively blind monitoring. When attackers spent 76 days exfiltrating data, the monitoring system couldn't see it happening.

Failure #3: No Network Segmentation. Defense in depth means assuming attackers will breach your perimeter, then limiting what they can reach. Equifax's flat network architecture meant that once attackers got past the initial web application, they had access to database servers holding crown jewel data. Proper segmentation would have made lateral movement difficult and might have contained the breach to a small subset of systems.

Failure #4: Unencrypted Data at Rest. Even if attackers reached the databases, encryption at rest would have made the stolen data useless without also stealing encryption keys. Equifax stored 147.9 million records in plain text. The attackers copied files and left with immediately usable information.

Failure #5: No Effective Anomaly Detection. Large-scale data exfiltration creates patterns. Unusual amounts of data leaving your network, especially from database servers to external destinations, should trigger alerts. For 76 days, nothing happened. Either Equifax didn't have anomaly detection, or it was configured so poorly that massive theft went unnoticed for months.

Each failure enabled the next step in the attack chain. The unpatched software gave initial access. The flat network allowed lateral movement. Unencrypted data made theft valuable. Failed monitoring let it continue undetected. This is what security professionals mean when they talk about defense in depth—or in Equifax's case, the catastrophic absence of it.

4 The Human and Financial Toll

For 147.9 million Americans, the breach created permanent vulnerability. Social Security numbers can't be changed. Unlike a password or credit card number, your SSN is with you for life. With a full profile—name, SSN, birth date, address—criminals can open credit

cards, file fraudulent tax returns, take out loans, commit medical fraud, and steal identities in ways that victims discover years later.

Equifax offered 10 years of free credit monitoring. That sounds helpful until you realize the data is compromised forever. Victims need to monitor their credit for life, freeze and unfreeze their files when applying for loans, watch for signs of identity theft, and deal with the anxiety of permanent exposure—all for data they never chose to give Equifax in the first place.

The financial costs to Equifax were substantial but perhaps not substantial enough. The company paid \$425 million for consumer settlement in a class action lawsuit, with individual victims eligible for \$125 to \$425 depending on documented harm. The Federal Trade Commission imposed a \$100 million fine. The Consumer Financial Protection Bureau added another \$100 million. Fifty state attorneys general collectively fined Equifax \$175 million. Legal fees ran \$242 million. Credit monitoring for victims cost \$350 million. Technology upgrades came to \$200 million.

Total direct costs: approximately \$1.4 billion. The stock price fell over 30%, erasing more than \$5 billion in market value. Per victim, Equifax spent roughly \$9.47 in direct costs. But so many victims filed claims that the average actual payout was \$2.88. That's the compensation for lifetime identity theft risk: less than a cup of coffee.

CEO Rick Smith resigned in September 2017 but kept \$90 million in stock and pension benefits. Chief Security Officer Susan Mauldin—a music major with limited security credentials who became a symbol of Equifax's governance failures—retired immediately after the breach. Chief Information Officer David Webb retired as well. Three executives who sold stock right after the breach was discovered internally but before it went public faced SEC scrutiny, though no criminal charges followed.

Meanwhile, victims who never chose to do business with Equifax, who had no say in how their data was protected, and who couldn't opt out of the system, received \$2.88 on average and a lifetime of vigilance.

5 What Should Have Happened

Industry best practices existed in 2017 for everything Equifax failed to do. Critical security patches should be applied within 24 to 48 hours of release, with emergency procedures for vulnerabilities as severe as CVE-2017-5638. Vulnerability scanning should be automated, verified, and followed by actual patching—not just reports that go ignored. SSL certificates should renew automatically with alerts well before expiration.

Network segmentation should separate systems by sensitivity and function. Database servers holding consumer credit data should live in isolated network zones, accessible only through carefully controlled pathways with logging and monitoring. If a web application gets compromised, attackers shouldn't be able to reach database servers directly.

Data encryption at rest should protect information even when attackers gain unauthorized access. Modern encryption can add minimal performance overhead while making

stolen data useless without keys stored separately and managed carefully.

Security monitoring should detect anomalies in real time. Large data transfers, especially from sensitive systems to external networks, should trigger immediate investigation. A Security Operations Center with 24/7 staffing should review alerts and respond to incidents. Intrusion detection systems should identify suspicious patterns of access.

These aren't exotic, expensive, or novel security measures. They're basic practices organizations with sensitive data had been implementing for years. Equifax just didn't do them—or did them so poorly they might as well have not existed.

6 Accountability and Incentives

The question of accountability hangs over this case. Who should be held responsible when a company's negligence exposes 147.9 million people to permanent identity theft risk?

CEO Rick Smith set security budgets and strategic priorities. Should he face criminal charges for negligence? He resigned but kept \$90 million. Is that acceptable? The CSO was responsible for security but apparently lacked the expertise or resources to do the job properly. What about the Board of Directors, which had no cybersecurity expertise and provided insufficient oversight? What about IT staff who didn't apply the patch or renew the SSL certificate—were they following orders from an understaffed, under-resourced department, or were they personally negligent?

Current law provides some answers: corporations pay fines, executives resign with golden parachutes, and life goes on. No Equifax executive faced criminal charges. The company paid substantial sums but continued operating. Within a few years, Equifax had recovered financially.

This outcome reveals a deeper problem with incentives. Equifax's business model doesn't reward security. Banks and lenders are the customers. They buy credit reports and scoring services. Consumers are the product—the source of data that gets packaged and sold. There's no competitive pressure to protect consumer data better than Experian or TransUnion, because consumers don't choose which bureau to use.

What would rational executives do in this structure? Security is expensive. It requires investment in people, technology, and processes. It slows down product development. It doesn't directly generate revenue. Cutting security costs increases short-term profit. The probability of a major breach seems low. Even if a breach happens, fines might be manageable compared to the accumulated savings from underinvestment.

Then the breach happens. The company pays \$1.4 billion. But over how many years? Spread across how many periods? With insurance covering some costs? Against revenue of \$3.4 billion annually? It's painful but survivable.

The current penalty structure doesn't change behavior. If security failures cost executives their personal wealth or their freedom, we might see different choices. If compensation to victims was \$1,000 or \$10,000 per person instead of \$2.88, the total cost would force companies to invest in prevention. If boards faced personal liability for inadequate

security oversight, they might hire directors with cybersecurity expertise.

As it stands, the incentives encourage exactly what happened: underinvest in security, accumulate technical debt, hope for the best, and if the worst happens, pay a fine that hurts but doesn't kill the business.

7 Lessons

This case teaches several principles that apply far beyond Equifax:

Patch management is non-negotiable. When a critical vulnerability is announced and a patch is available, you have hours, not weeks. Equifax had two months. That's not a tight deadline they narrowly missed—that's organizational failure to treat security as urgent. Critical patches should be tested and deployed within 24 to 48 hours. High severity patches should follow within a week. This requires processes, automation, and a culture that prioritizes security over convenience.

Defense in depth is required. Single points of failure guarantee total compromise. Every defensive layer should assume other layers will fail and should work independently to limit damage. Perimeter defenses will be breached—what stops lateral movement? Attackers will reach sensitive data—is it encrypted? Monitoring will miss things—do you have backups and recovery procedures?

Monitoring must actually work. Security theater creates false confidence without real protection. Deploying monitoring tools means nothing if SSL certificates expire and nobody notices for 19 months. Test your defenses. Run red team exercises. Attempt to breach your own systems and see if detection works. Equifax had monitoring deployed but not actually monitoring.

Data stewardship, not ownership. Companies that collect personal information don't own it. They're stewards with a fiduciary obligation to protect it. This is especially true when consumers have no choice about whether to provide their data. Equifax treated consumer credit information as a corporate asset to be monetized. A better frame is borrowed data requiring careful protection and limited use.

Incentives drive behavior. If we want better security outcomes, penalties need to hurt enough to change cost-benefit analysis. Right now, underinvesting in security and paying fines when breaches happen can be cheaper than doing security properly. That calculation needs to reverse.

8 Questions

1. **Technical Architecture:** Explain how defense in depth would have limited the Equifax breach. If the Apache Struts vulnerability had still been exploited, what other security layers could have prevented attackers from stealing 147.9 million records?
2. **Patch Management:** A critical patch was available March 7, 2017. The breach began in mid-May. Why might an organization fail to patch for two months despite having vulnerability scanners? What processes, tools, and cultural factors would prevent this?
3. **Monitoring Failures:** Equifax's SSL certificate expired 19 months before the breach, disabling effective traffic monitoring. How does this happen? What organizational failures does it reveal? How should certificate management work?
4. **Economic Incentives:** Equifax paid roughly \$1.4 billion in direct costs for a breach affecting 147.9 million people. Is this enough to incentivize proper security investment? How would you design a penalty structure that actually changes corporate behavior?
5. **Accountability:** CEO Rick Smith resigned but kept \$90 million in compensation. Should executives face personal financial consequences or criminal charges for security negligence? Where should we draw the line between business risk and criminal negligence?
6. **Consumer Protection:** Victims received an average of \$2.88 while facing lifetime identity theft risk. What would fair compensation look like? Should victims be able to sue individually, or are class actions sufficient?
7. **Market Structure:** Consumers don't choose credit bureaus and can't opt out. Does this create special obligations? Should credit bureaus be regulated as public utilities, face mandatory security standards, or be restructured entirely?
8. **Data Minimization:** Equifax collected extensive personal information including Social Security numbers, birth dates, and addresses. How much of this data is actually necessary for credit reporting? Should there be limits on what data can be collected and retained?
9. **Insider Trading:** Three executives sold \$1.8 million in stock after the breach was discovered internally but before public announcement. Even if they claimed ignorance, should this be prohibited? What policies prevent this?
10. **Comparative Analysis:** Under GDPR, this breach would likely trigger fines up to 4% of global revenue (roughly \$136 million) plus substantial victim compensation rights. Should the U.S. adopt similar data protection laws? What would the consequences be?

11. **Security vs. Business Goals:** Security often conflicts with speed, convenience, and cost. How should organizations balance these tensions? What role should boards play in security oversight?
12. **Vulnerability of SSNs:** Social Security numbers were designed in 1936 as account identifiers, not authenticators. Yet they've become de facto national ID numbers that can't be changed when compromised. Should we redesign this system? What would replace SSNs?